



Corporación Unificada Nacional de Educación Superior — CUN

Programa de Ingeniería de Sistemas

**COTEJO: PROGRAMA DE AUDITORÍA DE SISTEMAS CON VERIFICACIÓN
AUTOMATIZADA DE CONTROLES Y PAPELES DE TRABAJO REPRODUCIBLES**

ENTREGA 2 · AJUSTE AVANZADO DE PROYECTO

Presentado por:

Sergio Alejandro Montoya Granados

sergio.montoya@cun.edu.co

Nicolás Torres Perdomo

nicolas.perdomot@cun.edu.co

Oscar Julián Rincón Bejarano

oscar.rinconbbe@cun.edu.co

Auditoría de Sistemas (ISD39) · Grupo 30112 · Periodo 2026B

Bogotá, D. C., Colombia · Octubre de 2026



Corporación Unificada Nacional
de Educación Superior

Programa de Ingeniería de Sistemas

**COTEJO: PROGRAMA DE AUDITORÍA DE SISTEMAS CON VERIFICACIÓN
AUTOMATIZADA DE CONTROLES Y PAPELES DE TRABAJO REPRODUCIBLES**

Documento académico de proyecto

Presentado a:

Daniel Alejandro García Rodríguez

Asignatura: Auditoría de Sistemas (ISD39)

Versión: 1.0

Fecha de entrega: 3 de octubre de 2026

Corporación Unificada Nacional de Educación Superior — CUN

Bogotá, D. C., Colombia

Control del documento

La Tabla 1 identifica el proyecto, el equipo y la versión de este documento.

Tabla 1

Identificación del proyecto y del equipo de trabajo

Campo	Información
Título del proyecto	Cotejo: programa de auditoría de sistemas con verificación automatizada de controles y papeles de trabajo reproducibles
Asignatura y grupo	Auditoría de Sistemas (ISD39) · Grupo 30112 · Periodo 2026B
Integrantes	Sergio Alejandro Montoya Granados — sergio.montoya@cun.edu.co Nicolás Torres Perdomo — nicolas.perdomot@cun.edu.co Oscar Julián Rincón Bejarano — oscar.rinconbbe@cun.edu.co
Docente	Daniel Alejandro García Rodríguez
Sistema auditado	Rastro, sistema de trazabilidad de envíos desplegado por el mismo equipo en la cuenta AWS 484948252891, región us-east-1
Versión	1.0 — sustituye la versión 0.1 presentada en la Entrega 1
Repositorio de evidencias	https://github.com/Serann10255/Rastro Repositorio público. Contiene el programa, el catálogo de controles, las pruebas del propio programa y la documentación técnica.
Ejecución de referencia	20260926T235724886Z-4f87a8 · 26 de septiembre de 2026
Fecha de corte	3 de octubre de 2026

Tabla de contenido

Control del documento.....	3
Tabla de contenido.....	4
Matriz obligatoria de atención a la retroalimentación	7
1. Resumen ejecutivo, abstract y palabras clave.....	8
1.1 Resumen.....	8
1.2 Abstract and keywords.....	9
2. Introducción y evolución del proyecto	10
3. Problema, pregunta, objetivos y alcance ajustados.....	11
3.1 Problema y pregunta validados	11
3.2 Objetivos y trazabilidad	12
3.3 Alcance, exclusiones y restricciones.....	13
4. Marco referencial actualizado.....	14
4.1 Estado del arte y antecedentes	14
4.2 Marco teórico y conceptual.....	16
4.3 Marco contextual	17
4.4 Marco normativo, ético y de estándares	18
5. Partes interesadas, necesidades y requisitos consolidados	19
5.1 Actores y partes interesadas.....	19
5.2 Requisitos funcionales, no funcionales y criterios de aceptación.....	20

5.3 Historias de usuario, casos de uso o procesos.....	21
6. Arquitectura de la solución	22
6.1 Diagrama de contexto y límites	22
6.2 Componentes y catálogo de controles.....	23
6.3 Decisiones de arquitectura	25
7. Diseño detallado.....	26
7.1 Modelo de datos e información.....	26
7.2 Diseño de interfaces e interacción	27
7.3 Integraciones, API, protocolos y configuración	28
8. Implementación, configuración y prototipo.....	29
8.1 Evidencia de la implementación	29
9. Verificación, validación y pruebas	30
9.1 Estrategia de pruebas	30
9.2 Casos, resultados y defectos	31
9.3 Validación con usuarios o expertos	33
10. Seguridad, privacidad, ética y cumplimiento.....	34
11. Calidad, mantenibilidad y operación	36
12. Gestión del proyecto	37
12.1 Metodología, fases y roles	37
12.2 Cronograma e hitos	38

12.3 Repositorio, versiones y gestión de cambios	38
12.4 Presupuesto y recursos	39
13. Viabilidad y gestión de riesgos actualizadas	39
14. Resultados y discusión	41
15. Conclusiones, recomendaciones y trabajo futuro	42
15.1 Conclusiones	42
15.2 Recomendaciones y trabajo futuro	43
Referencias	45
Anexos técnicos	47

Matriz obligatoria de atención a la retroalimentación

La evaluación de la Entrega 1 registró una única observación, de prioridad baja. Se transcribe literal, con la acción aplicada, su ubicación y la evidencia. Se añaden dos correcciones que el propio equipo introdujo sobre el diseño documentado en la Entrega 1, porque describían mecanismos que no fueron los construidos y dejarlas sin corregir habría significado documentar funcionalidad inexistente.

La Tabla 2 recoge la observación recibida y las correcciones propias, con su estado y su evidencia.

Tabla 2

Atención a la retroalimentación de la Entrega 1

ID	Retroalimentación literal	Respuesta del equipo	Ubicación del cambio	Evidencia	Estado
OBS-01	«Propuesta de nivel profesional. Se sugiere adjuntar las ejecuciones en código (script Lambda/CLI) en el repositorio al iniciar la Fase 3. Acción requerida: subir la secuencia de comandos y la función Lambda ejecutora al repositorio Git.»	El programa completo se publicó en el repositorio: ejecutor, catálogo de controles, las tres familias de pruebas, el almacén de papeles de trabajo, el generador de informe, la interfaz de consulta y las pruebas del propio programa.	Apartados 8 y 12.3; carpeta cotejo/ del repositorio	https://github.com/Serann10255/Rastro	Resuelta
AC-01	Corrección propia: la Entrega 1 describía un sellado de los papeles de trabajo mediante firma asimétrica y publicación de una llave pública. El programa construido	Se corrigió la descripción para que coincidiera con lo construido. La firma asimétrica y el anclaje externo pasan a trabajo	Apartados 7.1 y 15.2	cotejo/cotejo/papeles.py	Resuelta

ID	Retroalimentación literal	Respuesta del equipo	Ubicación del cambio	Evidencia	Estado
	sella con función hash SHA-256 y no con firma digital.	futuro, con el problema concreto que resolverían: permitir la verificación sin entregar los papeles.			
AC-02	Corrección propia: la Entrega 1 comprometía un catálogo de ocho controles. El catálogo construido contiene diez entradas que producen once resultados, por la partición de un control en tres comprobaciones.	Se actualizó el alcance y la matriz de controles. La ampliación responde a un riesgo que se materializó durante la construcción y que el catálogo original no cubría.	Apartados 3.3 y 6.2	cotejo/catalogo/controles.yaml	Resuelta

Nota. La observación OBS-01 se transcribe con la redacción de la matriz de retroalimentación docente. Las correcciones propias se identifican con el prefijo AC para distinguirlas de las observaciones recibidas y de los hallazgos que emite el programa, que llevan su propia secuencia.

1. Resumen ejecutivo, abstract y palabras clave

1.1 Resumen

Las organizaciones que despliegan sistemas en la nube declaran controles de seguridad en sus documentos de diseño, pero rara vez disponen de un mecanismo que compruebe que esos controles están configurados y que funcionan. El objetivo fue desarrollar un programa de auditoría que verificara de forma automatizada y reproducible los controles de un sistema desplegado, y que produjera papeles de trabajo trazables a un marco de referencia. El método siguió la secuencia de un trabajo de aseguramiento: definición del universo auditable, derivación del catálogo desde marcos reconocidos, diseño del procedimiento y el criterio de cada prueba antes de ejecutarla, ejecución y comunicación de hallazgos. El resultado es Cotejo, un programa de unas 3.400 líneas que ejecuta tres familias de prueba sobre el sistema auditado: de cumplimiento contra la

configuración de la infraestructura, sustantivas ejercitando la aplicación con usuarios de prueba de distintos roles y organizaciones, y de integridad recalculando la cadena de funciones hash de la bitácora. Cada resultado conserva el procedimiento, la salida literal, la marca de tiempo y la huella criptográfica del archivo de evidencia. La ejecución de referencia contra el sistema desplegado evaluó once resultados de control y obtuvo diez conformes y uno desviado, ninguno sin ejecutar, y emitió tres hallazgos: uno corregible y dos permanentes derivados de restricciones del entorno. El programa detectó un problema real de seguridad introducido por el propio equipo, que la revisión manual no había advertido.

Palabras clave: auditoría de sistemas, auditoría continua, papeles de trabajo reproducibles, pruebas de cumplimiento y sustantivas, verificación automatizada de controles.

1.2 Abstract and keywords

Organisations that deploy systems in the cloud declare security controls in their design documents, yet they rarely have a mechanism that verifies whether those controls are actually configured and working. The objective was to develop an audit program that would verify, automatically and reproducibly, the controls of a deployed system, and that would produce working papers traceable to a reference framework. The method followed the sequence of an assurance engagement: definition of the auditable universe, derivation of the control catalogue from recognised frameworks, design of each test's procedure and acceptance criterion before execution, and execution and communication of findings. The result is Cotejo, a program of roughly 3,400 lines that runs three families of tests against the audited system: compliance tests against infrastructure configuration, substantive tests exercising the application with test users from different roles and organisations, and integrity tests recomputing the hash chain of the audit log. Each result retains

the procedure, the literal output, the timestamp and the cryptographic digest of the evidence file. The reference execution against the deployed system evaluated eleven control results and returned ten compliant and one deviated, none unexecuted, and issued three findings: one correctable and two permanent, arising from environment restrictions. The program detected a real security problem introduced by the team itself, which manual review had not noticed.

Keywords: information systems auditing, continuous auditing, reproducible working papers, compliance and substantive testing, automated control verification.

2. Introducción y evolución del proyecto

La Entrega 1 presentó Cotejo como una idea: un catálogo de ocho controles, un ejecutor por construir y un almacén de papeles de trabajo previsto. Este documento presenta el programa construido, ejecutado contra un sistema real desplegado en la nube, y el informe de auditoría que produjo. La diferencia entre ambos documentos es la que separa una propuesta de un resultado.

Tres cosas cambiaron durante la construcción, y las tres se corrigen en este documento en lugar de mantenerse por coherencia formal con lo prometido. La primera es el mecanismo de sellado. La Entrega 1 describía una firma asimétrica sobre el índice de papeles de trabajo y la publicación de una llave pública para que un tercero verificara sin acceder a la evidencia. El programa construido sella con función hash SHA-256, que permite a quien recibe los papeles confirmar que son los que el informe cita, pero no permite verificar sin tenerlos. Mantener la descripción original habría significado documentar funcionalidad inexistente, y la firma asimétrica pasa a trabajo futuro con el problema concreto que resolvería.

La segunda es la ampliación del catálogo. Durante la construcción se materializó un riesgo que el catálogo original no cubría: un secreto de firma quedó versionado en el repositorio público del

proyecto. Ese incidente produjo un control nuevo, partido en tres comprobaciones por una razón metodológica que se explica en el apartado 6.2. El catálogo pasó de ocho controles a diez entradas que producen once resultados.

La tercera es el alcance de la ejecución. La Entrega 1 preveía auditar un sistema que todavía no existía. La ejecución de referencia de este documento se realizó contra el sistema desplegado en la cuenta del laboratorio, no contra una pila local, lo que eleva el valor probatorio de cada papel de trabajo.

Lo que no cambió es el planteamiento: un control declarado no es un control verificado, y la distancia entre ambos solo se cierra ejercitando el sistema y conservando la prueba de lo que se hizo. Los apartados 3 a 5 presentan el problema y los requisitos del programa, del 6 al 8 su arquitectura, su diseño y su implementación, el 9 la verificación del propio programa y la ejecución de la auditoría, del 10 al 13 la seguridad, la calidad, la gestión y los riesgos, y los apartados 14 y 15 los resultados y las conclusiones.

3. Problema, pregunta, objetivos y alcance ajustados

3.1 Problema y pregunta validados

Un control declarado no es un control verificado. En un sistema desplegado en la nube, la afirmación de que los datos están cifrados, de que el registro de actividad está activo o de que una operación está restringida por rol suele apoyarse en un documento de diseño o en la memoria de quien configuró el servicio. La situación deseada es distinta: cada control con una prueba ejecutable asociada, una evidencia conservada y un resultado que un tercero pueda reproducir.

La distancia entre ambas situaciones se comprobó empíricamente antes de construir nada. El equipo configuró de forma deliberada un punto de acceso público sobre una función, con una

política de recurso que autoriza de manera explícita a cualquier principal, y después comprobó su comportamiento real: toda invocación se rechaza. La configuración declarada y el comportamiento efectivo se contradicen. Un procedimiento de auditoría basado en leer configuraciones habría concluido que existía un punto de acceso abierto, que es un hallazgo falso; uno basado en ejercitar el sistema concluye lo contrario. La observación es recuperable: el comando y la petición pueden repetirse y producen el mismo resultado.

La construcción del programa añadió una segunda validación del problema, esta vez no buscada. El propio equipo introdujo un defecto de seguridad real, un secreto de firma versionado en un repositorio público, y no lo advirtió en sus revisiones manuales del código y de la documentación. Lo detectó el control automatizado. Ese episodio es la mejor evidencia disponible de que el problema planteado existe: quien construye un sistema no es un buen verificador de sus propios controles.

La pregunta de proyecto se mantiene: ¿cómo diseñar y ejecutar un programa de auditoría que verifique de forma automatizada y reproducible los controles de un sistema desplegado en la nube, cubriendo tanto la configuración de la infraestructura como el comportamiento efectivo de los controles de la aplicación, y que produzca papeles de trabajo cuya integridad y trazabilidad puedan comprobarse por un tercero? El apartado 14 discute la respuesta obtenida y sus límites.

3.2 Objetivos y trazabilidad

Objetivo general. Desarrollar un programa de auditoría de sistemas que verifique de forma automatizada y reproducible los controles de configuración, de acceso y de integridad de una aplicación desplegada en Amazon Web Services, generando papeles de trabajo con evidencia recuperable y trazable a un marco de referencia reconocido.

La Tabla 3 traza cada objetivo específico hasta su evidencia y su estado de cumplimiento.

Tabla 3*Objetivos específicos, evidencia y estado de cumplimiento*

ID	Objetivo específico	Entregable	Evidencia verificable	Estado
OE-1	Definir el universo auditable y la matriz de controles, trazando cada control a un marco de referencia.	Catálogo de controles con criterio, marco y tipo de prueba declarados antes de ejecutar.	Apartado 6.2; archivo de catálogo en el repositorio.	Cumplido. Diez controles, once resultados.
OE-2	Diseñar el programa de pruebas de cumplimiento, sustantivas y de integridad con su criterio de aceptación.	Procedimiento, criterio y evidencia esperada por cada prueba.	Apartados 6.2 y 7; catálogo versionado con fecha anterior a la primera ejecución.	Cumplido
OE-3	Construir el ejecutor automatizado y el almacén de papeles de trabajo con verificación de integridad.	Programa operativo y almacén con huella por papel de trabajo.	Apartado 8; ejecución de referencia con sus once papeles y sus huellas.	Cumplido
OE-4	Ejecutar el programa, evaluar las desviaciones y emitir el informe de hallazgos.	Informe de auditoría con hallazgos clasificados por severidad.	Apartado 9.2; informe de la ejecución de referencia.	Cumplido. Tres hallazgos emitidos.

3.3 Alcance, exclusiones y restricciones

La Tabla 4 delimita el alcance vigente del programa de auditoría.

Tabla 4*Alcance vigente: elementos contruidos, excluidos y condicionados*

Condición	Elemento	Estado y justificación
Construido	Catálogo de diez controles con criterio, marco de referencia y tipo de prueba declarados antes de la ejecución.	Operativo. Produce once resultados por la partición del control de secretos.
Construido	Pruebas de cumplimiento sobre registro de actividad, cifrado, versionado y acceso público.	Operativo. Controles C-01 a C-04.
Construido	Pruebas sustantivas sobre autorización por rol, aislamiento entre organizaciones y transiciones de estado.	Operativo. Controles C-05 a C-07. Es la cobertura que ninguna herramienta disponible ofrece.
Construido	Prueba de integridad con recálculo de la cadena y alteración controlada.	Operativo. Control C-08, validado en doble sentido.

Condición	Elemento	Estado y justificación
Construido	Control de secretos en el repositorio, partido en árbol actual, historial y vigencia.	Operativo. Controles C-09a, C-09b y C-09c. Ampliación posterior a la Entrega 1.
Construido	Almacén de papeles de trabajo con procedimiento, salida literal, marca de tiempo y huella SHA-256.	Operativo.
Construido	Informe de hallazgos con condición, criterio, causa, efecto, severidad y recomendación, en lenguaje técnico y en lenguaje llano.	Operativo.
Construido	Interfaz de consulta de la auditoría, restringida al rol auditor.	Operativo. Cualquier otro rol recibe rechazo.
Excluido	Auditoría del proceso de desarrollo, revisión de código fuente y evaluación de continuidad del negocio.	Pertenecen a otros tipos de trabajo de aseguramiento.
Excluido	Pruebas de intrusión y explotación de vulnerabilidades.	Requieren autorización específica y competencias distintas.
Excluido	Vigilancia continua y desatendida de los controles.	El entorno detiene la sesión cada cuatro horas. El programa se ejecuta por demanda.
Excluido	Auditoría de sistemas distintos de Rastro.	El objeto se limita a un sistema para que la profundidad prime sobre la extensión.
Condicionado	Retención inmutable del almacén de papeles de trabajo.	No habilitada. El entorno no confirmó su disponibilidad. Se sustituye por huella criptográfica y se declara como limitación.
No aplica	Firma asimétrica del índice y publicación de llave pública.	Descrita en la Entrega 1 y no construida. Se retira del alcance vigente y pasa a trabajo futuro, según la corrección AC-01.

Las restricciones del entorno se mantienen: el equipo audita un sistema que él mismo construyó, no existen servicios gestionados de evaluación de configuración ni de gestión de evidencias, las credenciales caducan cada cuatro horas y el programa se ejecuta con el mismo rol compartido que dispone de permisos de escritura sobre lo que audita. Las dos últimas condiciones producen hallazgos permanentes que se declaran en cada informe.

4. Marco referencial actualizado

4.1 Estado del arte y antecedentes

La verificación automatizada de controles no es una idea nueva. Vasarhelyi y Halper (1991) describieron la auditoría continua de sistemas en línea como el desplazamiento de la revisión

periódica hacia la comprobación permanente y automatizada, ejecutada sobre el propio sistema y no sobre reportes derivados de él. Chan y Vasarhelyi (2011) revisaron dos décadas después su adopción práctica y señalaron que el obstáculo no era técnico sino organizativo: exige definir con precisión qué constituye una excepción y qué evidencia la sustenta, tarea que las auditorías tradicionales resolvían con criterio profesional caso por caso. Ese es exactamente el trabajo que el catálogo de controles de este proyecto formaliza, al obligar a declarar el criterio antes de ejecutar la prueba.

Del lado normativo, COBIT 2019 establece objetivos de gestión sobre servicios de seguridad y sobre controles de procesos de negocio (ISACA, 2018); ITAF fija las normas de desempeño y de comunicación aplicables a un trabajo de aseguramiento, incluida la exigencia de evidencia suficiente y confiable (ISACA, 2020); ISO/IEC 27001 define los requisitos de un sistema de gestión de seguridad de la información (International Organization for Standardization, 2022); y el conjunto de recomendaciones del Center for Internet Security (s. f.) traduce esos principios a configuraciones concretas de una cuenta de nube. Sobre el registro de actividad, Kent y Souppaya (2006) fijan qué debe conservar una entrada de auditoría, y Schneier y Kelsey (1999) demostraron cómo encadenar registros para que una alteración posterior resulte detectable, técnica que el control C-08 verifica sobre el sistema auditado.

La Tabla 5 compara los enfoques de verificación frente a los criterios que interesan al problema.

Tabla 5

Comparación de enfoques de verificación de controles

Enfoque	Cobertura de infraestructura	Cobertura del comportamiento de la aplicación	Reproducibilidad de la evidencia	Disponibilidad en el entorno
Revisión manual con capturas de pantalla	Parcial y puntual.	Posible, pero dependiente del	Baja: la captura no conserva el	Disponible; es la práctica habitual.

Enfoque	Cobertura de infraestructura	Cobertura del comportamiento de la aplicación	Reproducibilidad de la evidencia	Disponibilidad en el entorno
		criterio de quien la ejecuta.	comando ni permite repetir la prueba.	
Lista de verificación documental	Nula: verifica lo declarado, no lo configurado.	Nula.	Media: el documento es estable, pero no acredita el estado del sistema.	Disponible.
Servicios gestionados de evaluación de configuración	Alta y continua.	Nula: no ejercitan la lógica de autorización de la aplicación.	Alta dentro de la plataforma del proveedor.	No disponible en el entorno del proyecto.
Programa propio de verificación automatizada	Alta, limitada a los controles programados.	Alta: invoca la aplicación con usuarios de prueba por rol y organización.	Alta: conserva comando, salida, fecha y huella.	Disponible; requiere construirlo.

Nota. La comparación se construyó sobre enfoques y no sobre productos específicos, con el fin de no atribuir características concretas a proveedores sin verificación directa.

El vacío se lee en las dos columnas centrales y la construcción lo confirmó. Los servicios gestionados evalúan la configuración con solvencia, pero no pueden saber si un usuario del rol conductor logra crear un envío ni si un usuario de una organización alcanza los datos de otra, porque esas reglas viven en el código. Las revisiones manuales sí llegan allí, pero producen evidencia que nadie puede repetir. De los once resultados de la ejecución de referencia, cuatro corresponden a comportamiento de la aplicación y no habrían sido verificables por ninguna herramienta de configuración.

4.2 Marco teórico y conceptual

Cuatro conceptos sostienen el diseño del programa. El primero es la distinción entre **prueba de cumplimiento** y **prueba sustantiva**. La primera comprueba que un control existe y está configurado; la segunda comprueba que produce el efecto esperado cuando el sistema se usa. Un

control puede estar perfectamente configurado y no funcionar, y esa posibilidad es la que justifica el proyecto.

El segundo es el **papel de trabajo** como unidad de evidencia. Un papel de trabajo no es una captura: conserva el procedimiento ejecutado, la salida literal sin editar, el momento, la identidad bajo la que se ejecutó y una huella que hace detectable su modificación posterior. Sin esas cinco piezas, un resultado de auditoría es una afirmación.

El tercero es la **tercera conclusión posible**. Además de conforme y desviado, el programa admite el estado no ejecutado, para los controles que no pudieron probarse. Mezclar ese estado con cualquiera de los otros dos informa más cobertura de la que hubo: lo que no se pudo revisar no está aprobado, está pendiente. El informe los cuenta por separado.

El cuarto es la **validación en doble sentido**. Comprobar que una prueba informa conformidad cuando el control está bien no demuestra que la prueba sirva: una prueba mal escrita que siempre devuelva conforme pasaría ese examen. Demostrarlo exige verificar que informa desviación cuando el control se rompe a propósito. El control C-08 se valida así, y el apartado 9.1 explica por qué no todos pueden serlo.

4.3 Marco contextual

El objeto de auditoría es Rastro, un sistema de trazabilidad de envíos desplegado en AWS Academy Learner Lab y construido por los mismos integrantes en el marco de otra asignatura. Esa condición tiene una ventaja y un costo. La ventaja es el acceso completo a la configuración, al código y a los registros, que permite construir pruebas que un auditor externo no alcanzaría. El costo es una amenaza a la independencia que se declara y se atiende en el apartado 10.

El entorno impone tres condiciones relevantes: las credenciales caducan cada cuatro horas, el presupuesto es limitado y no están disponibles los servicios gestionados de evaluación continua de

configuración que un auditor usaría en producción. Esa última ausencia es la que obliga a construir el programa y la que convierte el proyecto en un ejercicio de ingeniería y no en la operación de una herramienta comercial.

4.4 Marco normativo, ético y de estándares

La condición ética dominante es la independencia. El código de ética profesional para auditores de sistemas exige objetividad y la revelación de cualquier circunstancia que pueda comprometerla (ISACA, s. f.). El equipo declara la amenaza de autorrevisión y aplica tres medidas, descritas en el apartado 10, sin afirmar que alcancen el grado de independencia de una revisión externa.

La Tabla 6 relaciona cada marco aplicado con el control que lo materializa.

Tabla 6

Marcos de referencia aplicados y su materialización en el catálogo

Marco o norma	Aspecto que regula	Control del catálogo que lo materializa
COBIT 2019, DSS05 y DSS06 (ISACA, 2018)	Servicios de seguridad y controles de procesos de negocio.	C-05 autorización por rol, C-06 aislamiento entre organizaciones y C-07 validez de las transiciones.
ITAF (ISACA, 2020)	Normas de desempeño y de comunicación de un trabajo de aseguramiento.	Estructura del informe y exigencia de evidencia suficiente y confiable; secuencia metodológica del apartado 12.1.
ISO/IEC 27001:2022, A.8.24 y A.8.13 (International Organization for Standardization, 2022)	Criptografía y copias de seguridad.	C-02 cifrado con llave administrada y rotación; C-04 versionado del almacén.
ISO/IEC 27001:2022, A.5.17 y A.8.4	Información de autenticación y acceso al código fuente.	C-09a, C-09b y C-09c sobre secretos en el repositorio.
CIS AWS Foundations Benchmark (Center for Internet Security, s. f.)	Configuración segura de una cuenta de nube.	C-01 registro de actividad con validación de integridad; C-03 bloqueo de acceso público.
NIST SP 800-92 (Kent y Souppaya, 2006)	Gestión de registros de seguridad.	C-01, en cuanto a qué debe conservar y proteger un registro de auditoría.
NIST SP 800-57 Parte 1 (Barker, 2020)	Compromiso y retiro de llaves criptográficas.	C-09c, que comprueba que un secreto hallado ya no es aceptado por el sistema.

Marco o norma	Aspecto que regula	Control del catálogo que lo materializa
Schneier y Kelsey (1999); Haber y Stornetta (1991)	Registros encadenados a prueba de manipulación.	C-08, con validación en doble sentido.
Código de ética profesional (ISACA, s. f.)	Independencia y objetividad del auditor.	Hallazgo permanente sobre la autorrevisión y medidas del apartado 10.
Marco de buenas prácticas del proveedor, pilar de seguridad (Amazon Web Services, 2024)	Principio de mínimo privilegio.	Hallazgo permanente sobre el rol de ejecución compartido, fuera del alcance automatizado.

En lo legal, los papeles de trabajo pueden contener fragmentos de los datos del sistema auditado.

Como este opera exclusivamente con datos sintéticos, la evidencia no incorpora información personal y el proyecto no genera obligaciones bajo la Ley 1581 de 2012. Si el programa se aplicara a un sistema en producción, la evidencia sí quedaría cubierta por esa norma y exigiría minimización y acceso restringido; el diseño ya contempla lo segundo.

5. Partes interesadas, necesidades y requisitos consolidados

5.1 Actores y partes interesadas

La Tabla 7 relaciona cada actor con su necesidad y su relación con el programa construido.

Tabla 7

Actores del proceso de auditoría

Actor	Papel en la auditoría	Necesidad observable	Relación con el programa
Auditor	Define el universo auditable, ejecuta el programa y emite los hallazgos.	Obtener evidencia que sostenga una conclusión sin depender de la palabra del auditado.	Usuario principal. Ejecuta por línea de comandos y consulta por la interfaz.
Responsable técnico del sistema auditado	Construyó y opera el componente evaluado; recibe los hallazgos y define la corrección.	Entender qué falló, con qué evidencia y qué debe cambiar.	Destinatario del informe. No tiene permiso para modificar los papeles de trabajo.
Responsable del proyecto	Decide sobre la aceptación o corrección de cada hallazgo según su severidad.	Priorizar correcciones con criterio de riesgo y en lenguaje comprensible.	Destinatario del informe consolidado, que incluye una versión en lenguaje llano.

Actor	Papel en la auditoría	Necesidad observable	Relación con el programa
Evaluador independiente	Reejecuta el programa para comprobar que el resultado reportado se reproduce.	Verificar la auditoría sin repetir el trabajo manualmente.	Ejecuta el mismo programa y coteja clasificaciones y huellas.

Nota. El responsable técnico es el auditado y no un usuario del programa. De esa distinción depende la separación de funciones descrita en el apartado 12.1.

5.2 Requisitos funcionales, no funcionales y criterios de aceptación

Los nueve requisitos comprometidos en la Entrega 1 se mantienen. Se añade la columna de verificación con el conjunto de pruebas del propio programa que comprueba cada uno, y se ajusta el criterio de REQ-03 conforme a la corrección AC-01, porque distingue dos huellas con propósitos distintos.

La Tabla 8 relaciona cada requisito del programa con su criterio y la evidencia que lo verifica.

Tabla 8

Requisitos consolidados del programa con su verificación

ID	Tipo	Requisito	Criterio de aceptación	Verificación
REQ-01	F	Ejecutar el catálogo completo en una sola invocación, sin intervención manual.	Dada una invocación, cuando termina, entonces existe un resultado registrado para cada control del catálogo y la ejecución queda marcada como completa.	cotejo/tests/test_cotejo.py; ejecución de referencia con once resultados.
REQ-02	F	Conservar por cada prueba el comando o petición ejecutada, su salida literal y la marca de tiempo.	Dado un papel de trabajo, cuando se consulta, entonces contiene el procedimiento exacto, la salida sin editar y la fecha y hora de ejecución.	cotejo/tests/test_cotejo.py; once papeles de la ejecución de referencia.
REQ-03	F	Calcular y almacenar la huella criptográfica del archivo de evidencia de cada prueba.	Dado un archivo de evidencia, cuando se recalcula su huella, entonces coincide con la almacenada en el índice; y si el archivo se modifica, entonces deja de coincidir.	cotejo/tests/test_cotejo.py; huellas publicadas en el informe.
REQ-04	F	Comparar el resultado obtenido contra el criterio definido y clasificarlo como	Dado un control con criterio definido, cuando se ejecuta su prueba, entonces el resultado queda clasificado y	cotejo/tests/test_cotejo.py; informe con las tres conclusiones diferenciadas.

ID	Tipo	Requisito	Criterio de aceptación	Verificación
		conforme, desviado o no ejecutado.	la clasificación no depende de interpretación posterior.	
REQ-05	F	Ejecutar pruebas sustantivas autenticándose con usuarios de prueba de distintos roles y organizaciones.	Dado un usuario del rol conductor, cuando el programa invoca una operación de administración, entonces registra el código de respuesta y el registro producido en la bitácora del sistema auditado.	cotejo/tests/test_contrato_con_rastro.py; controles C-05 a C-07.
REQ-06	F	Verificar la integridad de la bitácora recalculando su cadena de funciones hash.	Dada una bitácora íntegra, cuando se ejecuta el verificador, entonces informa cadena válida; y tras una alteración controlada, entonces informa el punto de ruptura.	cotejo/cotejo/pruebas/integridad.py; control C-08.
REQ-07	NF	Impedir la modificación silenciosa de la evidencia almacenada.	Dado un archivo de evidencia, cuando se modifica, entonces la huella almacenada deja de coincidir con el contenido actual.	cotejo/tests/test_cotejo.py; apartado 7.1.
REQ-08	NF	Permitir a un tercero reejecutar el programa y obtener el mismo resultado para cada control.	Dado un sistema auditado sin cambios, cuando un evaluador distinto ejecuta el programa, entonces obtiene la misma clasificación para todos los controles.	Dos ejecuciones sucesivas del 26 de septiembre; apartado 9.2.
REQ-09	NF	Hacer que cada hallazgo del informe remita al papel de trabajo que lo sustenta.	Dado un hallazgo, cuando se sigue su referencia, entonces se llega al papel de trabajo con la evidencia y la huella que lo respaldan.	Informe de la ejecución de referencia; tres hallazgos con su papel y su huella.

Nota. F corresponde a requisito funcional y NF a no funcional. El criterio de REQ-03 se ajustó conforme a la corrección AC-01: la huella se calcula sobre el archivo y detecta su modificación, sin pretender la coincidencia entre ejecuciones distintas, que sería imposible porque cada salida contiene marcas de tiempo.

5.3 Historias de usuario, casos de uso o procesos

El proceso de auditoría se ejecuta en cuatro pasos. El auditor invoca el programa indicando el entorno contra el que trabajar. El ejecutor recorre el catálogo control por control, consultando la interfaz de configuración del proveedor para las pruebas de cumplimiento y autenticándose con usuarios de prueba para las sustantivas. Cada resultado se guarda como papel de trabajo con su huella y se compara contra el criterio declarado. Al terminar, el programa genera el informe,

clasifica las desviaciones como hallazgos y devuelve un código de salida distinto según haya conformidad total, desviaciones o controles sin ejecutar.

Un detalle del diseño merece mención porque define la naturaleza del programa: las pruebas sustantivas crean envíos de prueba en el sistema auditado. No es un efecto colateral indeseado sino el método: se prueba el sistema usándolo. Un auditor que solo lee no puede afirmar que un control funcione.

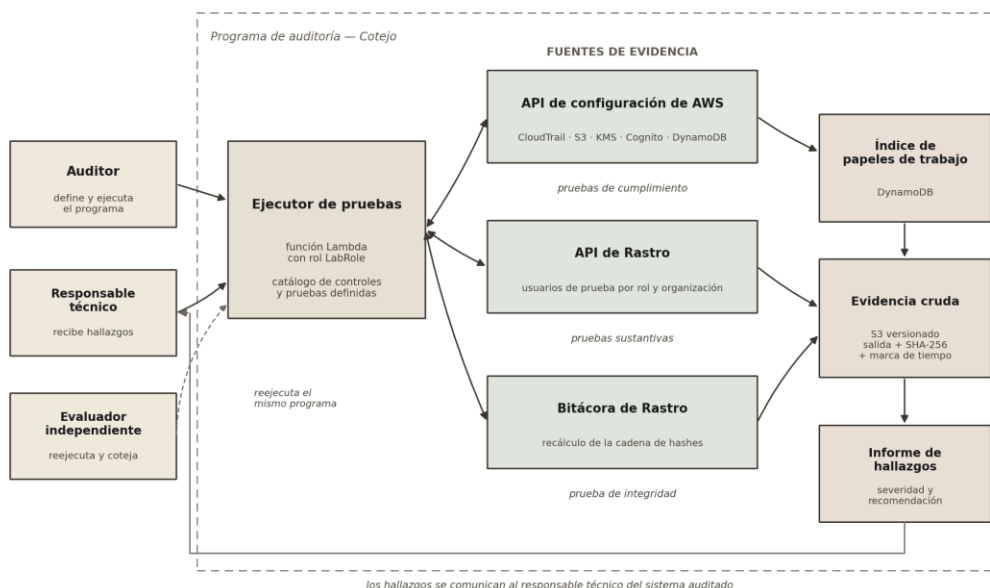
6. Arquitectura de la solución

6.1 Diagrama de contexto y límites

La Figura 1 sitúa el programa frente a sus actores, sus fuentes de evidencia y sus productos.

Figura 1

Arquitectura del programa de auditoría y sus fuentes de evidencia



Nota. Las tres fuentes de evidencia corresponden a las tres familias de prueba del catálogo. El ejecutor es el único componente que escribe en el almacén de papeles de trabajo; ningún actor lo modifica directamente. La línea inferior representa la comunicación de hallazgos al responsable técnico, que es el auditado y no un usuario del programa.

El límite de responsabilidad es explícito. El programa responde por la ejecución de las pruebas declaradas, la conservación íntegra de la evidencia y la clasificación conforme al criterio previo. No responde por la corrección de los hallazgos, que corresponde al responsable técnico, ni por los controles ausentes del catálogo, cuya exclusión se declara en cada informe.

6.2 Componentes y catálogo de controles

El programa se organiza en seis componentes. El **catálogo** declara los controles en un archivo de datos y no en el código, de modo que añadir un control no exige modificar el ejecutor. El **contexto** resuelve la conexión al entorno, local o de nube. El **ejecutor** recorre el catálogo y coordina. Las tres familias de **pruebas** implementan cada tipo de comprobación. El **almacén de papeles** escribe la evidencia y calcula las huellas. El **generador de informe** produce la salida en lenguaje técnico y en lenguaje llano. Sobre ellos hay una interfaz de línea de comandos y una interfaz web de consulta restringida al rol auditor.

El catálogo declara cuatro cosas de cada control antes de ejecutarlo: contra qué marco se juzga, qué tipo de prueba lo comprueba, cuál es el criterio de aceptación y qué evidencia debe quedar. Declararlas antes es lo que impide que el criterio se acomode al resultado. Declara además una versión en lenguaje llano de cada control, que no es decoración: un control que no puede explicarse sin vocabulario técnico no puede discutirse con quien decide, y un hallazgo que nadie entiende no se corrige.

La Tabla 9 presenta el catálogo de controles con su marco y su tipo de prueba.

Tabla 9

Catálogo de controles del sistema auditado

ID	Control	Marco de referencia	Tipo de prueba	Evidencia esperada
C-01	El registro de actividad está activo y con validación de integridad de sus archivos.	CIS AWS Foundations Benchmark; NIST SP 800-92	Cumplimiento	Estado del registro con el indicador de validación habilitado.
C-02	Las evidencias se cifran en reposo con llave administrada por el responsable, con rotación habilitada.	ISO/IEC 27001:2022, A.8.24	Cumplimiento	Cifrado por omisión, estado de rotación y objeto almacenado con cifrado declarado.
C-03	El almacén de evidencias no admite acceso público.	CIS AWS Foundations Benchmark	Cumplimiento	Los cuatro indicadores de bloqueo activos.
C-04	El almacén conserva versiones anteriores de cada objeto.	ISO/IEC 27001:2022, A.8.13	Cumplimiento	Versionado en estado habilitado.
C-05	Cada operación está restringida a los roles autorizados y el intento rechazado queda registrado.	COBIT 2019, DSS05; OWASP Top 10:2021 A01	Sustantiva	Respuesta 403 y registro en la bitácora con resultado DENY.
C-06	Un usuario no accede a envíos, eventos ni evidencias de otra organización.	COBIT 2019, DSS05; OWASP Top 10:2021 A01	Sustantiva	Respuesta 404 y no 403 en toda ruta, más el registro del intento.
C-07	El sistema rechaza las transiciones de estado no contempladas.	COBIT 2019, DSS06	Sustantiva	Respuesta 400 y registro con motivo de transición inválida.
C-08	La bitácora permite detectar la alteración o eliminación de cualquiera de sus registros.	Schneier y Kelsey (1999); Haber y Stornetta (1991)	Integridad	Cadena válida sobre la bitácora íntegra y punto de ruptura señalado sobre la copia alterada.
C-09a	Ningún secreto está versionado en el árbol actual del repositorio.	ISO/IEC 27001:2022, A.5.17 y A.8.4	Cumplimiento	Recorrido de los archivos del árbol actual, registrando ruta y nunca el valor.
C-09b	Ningún secreto aparece en el historial de commits.	ISO/IEC 27001:2022, A.5.17 y A.8.4	Cumplimiento	Recorrido del historial commit por commit.
C-09c	Ningún secreto hallado es aceptado por el sistema auditado.	ISO/IEC 27001:2022, A.5.17; NIST SP 800-57 Parte 1 (Barker, 2020)	Sustantiva	Token firmado con cada secreto hallado, rechazado con 401 por firma inválida.

Nota. El catálogo se deriva de los marcos citados y no de la apreciación del equipo, de modo que un control ausente pueda atribuirse a una decisión de alcance y no a un olvido. El detector de secretos registra la ruta y el commit, nunca el valor encontrado: un papel de trabajo que citara el secreto volvería a exponerlo.

La partición de C-09 en tres comprobaciones responde a una razón metodológica y no a comodidad. Un control único que preguntara si hay secretos en el repositorio produciría un resultado que mezcla dos condiciones de riesgo muy distinto: un secreto vivo publicado y un secreto invalidado que solo persiste en el historial. Separarlas permite que el informe diga la verdad completa: el árbol actual está limpio, el historial conserva un secreto, y ese secreto ya no abre nada. La severidad de cada comprobación se declara por separado.

6.3 Decisiones de arquitectura

La Tabla 10 resume las decisiones de arquitectura del programa con sus consecuencias.

Tabla 10

Decisiones de arquitectura del programa de auditoría

Decisión	Alternativa considerada	Criterio determinante	Consecuencia asumida
Catálogo en archivo de datos y no en el código.	Controles escritos en el programa.	Un control debe poder añadirse o ajustarse sin tocar el ejecutor, y el criterio debe ser legible por quien no programa.	Aparece una fuente de datos que puede discrepar del código; se cubre con pruebas del propio catálogo.
Verificación por ejecución y no por lectura de configuración.	Inspección de parámetros del proveedor.	La prueba preliminar demostró que la configuración declarada puede contradecir el comportamiento efectivo.	El programa crea datos de prueba en el sistema auditado. Es el método, no un efecto indeseado.
Tres conclusiones posibles en lugar de dos.	Conforme o desviado.	Lo que no se pudo revisar no está aprobado. Mezclarlo con cualquiera de los otros dos estados informa más cobertura de la que hubo.	El informe debe explicar la tercera conclusión, que no es intuitiva para quien lee.
Índice y evidencia separados.	Un único archivo por ejecución.	Permite comparar ejecuciones sin abrir los archivos y conservar la salida cruda sin transformarla.	Dos artefactos que deben mantenerse coherentes; la huella es lo que los ata.

Decisión	Alternativa considerada	Criterio determinante	Consecuencia asumida
Sellado por función hash y no por firma digital.	Firma asimétrica con llave no extraíble.	La firma exigía una funcionalidad adicional que no se construyó. Documentarla sin construirla habría sido describir lo inexistente.	Un tercero puede verificar que los papeles son los citados, pero necesita tenerlos. Pasa a trabajo futuro.
Informe en lenguaje técnico y en lenguaje llano.	Solo informe técnico.	Un hallazgo que el responsable no entiende no se corrige.	El catálogo debe declarar ambas versiones, lo que duplica el trabajo de definir cada control.

7. Diseño detallado

7.1 Modelo de datos e información

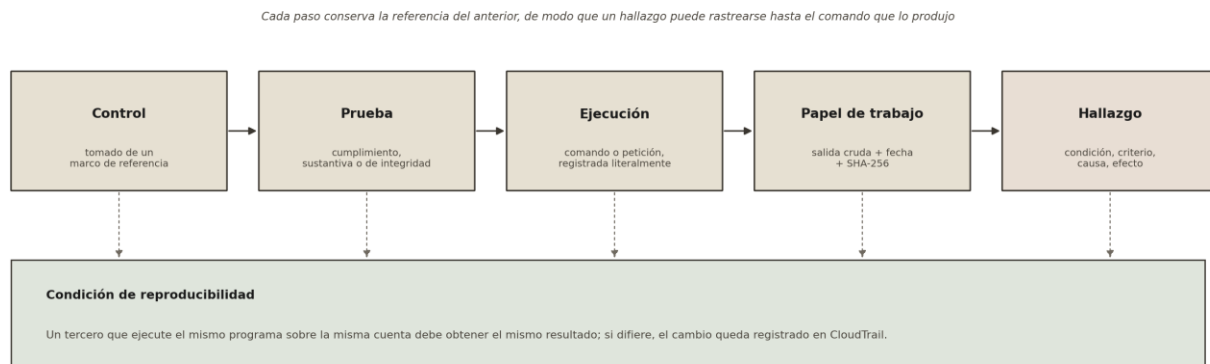
El almacén de papeles de trabajo se organiza en dos partes. Un índice conserva, por cada ejecución y control, el identificador del control, el tipo de prueba, el criterio, el resultado obtenido, la conclusión, la identidad de sesión bajo la que se ejecutó, la marca de tiempo y la huella criptográfica del archivo de evidencia. El archivo de evidencia, con la salida literal y sin edición, se guarda aparte. La separación permite consultar y comparar ejecuciones sin abrir los archivos y conservar la salida cruda sin transformarla.

La huella se calcula con SHA-256 sobre el archivo de evidencia, que es la misma función que encadena la bitácora del sistema auditado. Es lo que hace detectable una modificación posterior: si alguien edita el archivo, deja de coincidir con la almacenada en el índice. Conviene precisar su alcance, y esta precisión corrige lo descrito en la Entrega 1. La huella permite a quien recibe los papeles confirmar que son los que el informe cita; **no** permite a un tercero verificar sin tenerlos, ni protege frente a quien pueda alterar simultáneamente el archivo y el índice. Esa segunda garantía exigiría firma asimétrica y anclaje externo, que figuran como trabajo futuro.

La Figura 2 detalla el ciclo de vida de un papel de trabajo y la condición de reproducibilidad.

Figura 2

Ciclo de vida de un papel de trabajo y condición de reproducibilidad



Nota. Cada paso conserva la referencia del anterior, de modo que un hallazgo del informe puede rastrearse hasta el procedimiento que lo produjo y a la inversa. La reproducibilidad se verifica comparando la clasificación de los controles entre dos ejecuciones y recalculando la huella de cada archivo conservado.

Cada control produce una estructura con la misma forma: identificador, tipo de prueba, criterio declarado, observaciones recogidas durante la ejecución, conclusión y, cuando la conclusión es desviada, el hallazgo con su condición, criterio, causa, efecto, severidad y recomendación. Esa uniformidad es la que permite que el informe se genere sin intervención y que dos ejecuciones sean comparables.

7.2 Diseño de interfaces e interacción

El programa se opera de dos formas. La línea de comandos es la vía principal del auditor: recibe el entorno objetivo, ejecuta el catálogo y devuelve un código de salida que distingue tres situaciones, conformidad total, presencia de desviaciones y presencia de controles sin ejecutar. Esa distinción en el código de salida permite integrar el programa en una cadena automatizada sin leer el informe.

La interfaz web presenta la última ejecución, el resultado por control con su versión en lenguaje llano y los hallazgos. Está restringida al rol auditor: cualquier otro rol recibe rechazo, y esa restricción no es cosmética, porque el informe enumera las debilidades del sistema auditado.

El informe se emite en dos registros dentro del mismo documento. Abre con una sección en lenguaje llano que explica qué se revisó, qué salió y cómo se leen las tres conclusiones, y continúa con el detalle técnico por control, sus hallazgos y las limitaciones declaradas. La decisión de que ambas versiones vivan en el catálogo, y no en la interfaz, garantiza que la consola, el informe y la web digan exactamente lo mismo.

7.3 Integraciones, API, protocolos y configuración

El programa se integra con dos sistemas por vías distintas. Con la infraestructura del proveedor, mediante su interfaz de programación en modo lectura, para las pruebas de cumplimiento: estado del registro de actividad, configuración de cifrado y rotación de la llave, bloqueo de acceso público y estado de versionado. Con el sistema auditado, mediante su interfaz HTTP pública, autenticándose como cualquier usuario haría.

La Tabla 11 detalla las integraciones del programa y lo que cada una comprueba.

Tabla 11

Integraciones del programa y su finalidad

Integración	Protocolo y modo	Qué comprueba
Interfaz de configuración del proveedor	Interfaz de programación del proveedor, operaciones de lectura.	Estado del registro de actividad y su validación de integridad, cifrado por omisión y rotación de la llave, bloqueo de acceso público y versionado del almacén.
Interfaz del sistema auditado	HTTP sobre TLS, con token de sesión obtenido por el propio programa.	Comportamiento efectivo de la autorización por rol, del aislamiento entre organizaciones y de la máquina de estados, con verificación del registro producido en la bitácora.

Integración	Protocolo y modo	Qué comprueba
Servicio de identidad del sistema auditado	HTTP sobre TLS, contrato verificado por prueba específica.	Que el programa obtiene tokens válidos para cada rol y organización. Una prueba de contrato detecta cualquier cambio en el formato del token.
Repositorio de código	Lectura del árbol de trabajo y del historial de commits.	Presencia de secretos en el árbol actual y en el historial, registrando ruta y commit y nunca el valor.

Nota. Las credenciales de los usuarios de prueba se suministran al programa por variable de entorno y no se escriben en el código ni se versionan. La prueba de contrato con el servicio de identidad existe porque el programa depende de un formato de token que no controla.

La configuración del programa no contiene secretos. El entorno objetivo se indica por parámetro, la dirección del sistema auditado se lee de la configuración del despliegue y las credenciales de prueba llegan por variable de entorno. Esa decisión es consecuencia directa del incidente descrito en el apartado 10.

8. Implementación, configuración y prototipo

El programa está construido y ejecutado contra un sistema real. Reside en el repositorio público del proyecto, en una carpeta propia que reúne el catálogo, el ejecutor, las tres familias de pruebas, el almacén de papeles, el generador de informe, la interfaz de consulta y las pruebas del propio programa.

8.1 Evidencia de la implementación

La Tabla 12 inventaría los componentes construidos del programa.

Tabla 12

Componentes construidos del programa de auditoría

Componente	Extensión	Responsabilidad
Catálogo de controles	Archivo de datos	Declara los diez controles con su criterio, su marco, su tipo de prueba y su versión en lenguaje llano.
Ejecutor	182 líneas	Recorre el catálogo, coordina las pruebas y compone el resultado de la ejecución.

Componente	Extensión	Responsabilidad
Pruebas de cumplimiento	226 líneas	Consultan la configuración del proveedor en modo lectura.
Pruebas sustantivas	312 líneas	Se autentican con usuarios de prueba y ejercitan el sistema auditado.
Pruebas de integridad	185 líneas	Recalculan la cadena de la bitácora y validan el verificador en doble sentido.
Almacén de papeles de trabajo	215 líneas	Escribe índice y evidencia, y calcula la huella de cada archivo.
Generador de informe	396 líneas	Emite el informe en lenguaje técnico y en lenguaje llano, con hallazgos y limitaciones.
Interfaz de línea de comandos	325 líneas	Punto de entrada del auditor. Devuelve código de salida diferenciado.
Interfaz web de consulta	Aplicación web y servicio propio de 398 líneas	Presenta la última ejecución al rol auditor.
Pruebas del propio programa	34 pruebas	Catálogo, papeles de trabajo, reproducibilidad, informe y contrato con el servicio de identidad.

Nota. El recuento de líneas corresponde a los archivos del programa sin contar la interfaz web ni las pruebas. El total del módulo asciende a unas 3.400 líneas.

La ejecución de referencia se realizó el 26 de septiembre de 2026 contra el sistema desplegado en la cuenta 484948252891, región us-east-1, bajo la identidad de sesión del laboratorio. Produjo once papeles de trabajo, cada uno con su archivo de evidencia y su huella, y un informe. El código de salida fue distinto de cero por la presencia de una desviación, que es el comportamiento esperado.

El programa puede ejecutarse además contra la pila local del sistema auditado, sin credenciales del proveedor. Esa capacidad no es un atajo: permite a un tercero ejercitar el programa y comprobar su funcionamiento sin acceso a la cuenta, y fue la vía por la que se desarrollaron las pruebas antes de que el sistema estuviera desplegado.

9. Verificación, validación y pruebas

9.1 Estrategia de pruebas

Un programa de auditoría plantea un problema particular: quién verifica al verificador. La estrategia lo aborda en dos planos. El primero son las pruebas automatizadas del propio programa, que comprueban que el catálogo se carga correctamente, que los papeles conservan lo que deben, que la huella detecta una modificación, que el informe se genera con la estructura esperada y que el contrato con el servicio de identidad del sistema auditado sigue siendo válido.

El segundo plano es la **validación en doble sentido**, que es el control más importante de la estrategia. Comprobar que una prueba informa conformidad no demuestra que sirva: una prueba mal escrita que siempre devolviera conforme pasaría ese examen y produciría papeles de trabajo perfectamente íntegros y completamente inútiles. Demostrarlo exige verificar que informa desviación cuando el control se rompe a propósito.

El control C-08 se valida así de forma integrada: el programa recalcula la cadena sobre la bitácora íntegra y, además, altera deliberadamente una copia para confirmar que el verificador señala el punto exacto de la ruptura. Para los controles de cumplimiento la validación en doble sentido no está automatizada, y conviene decirlo con precisión: romper a propósito el cifrado o el bloqueo de acceso público del sistema desplegado tiene un coste y un riesgo que el equipo no asumió durante el periodo de la entrega. Queda como trabajo futuro con su justificación.

Hay un caso en el que la validación en doble sentido ocurrió sin buscarla, y es el más concluyente. El control de secretos detectó un secreto real introducido por el propio equipo en el repositorio público. No fue una alteración simulada: fue un defecto genuino que la revisión manual no había advertido y que el control encontró.

9.2 Casos, resultados y defectos

Las 34 pruebas del programa se ejecutan junto con las del sistema auditado en una suite única que termina en unos catorce segundos y no requiere credenciales del proveedor. En la última ejecución, la suite completa registró 234 pruebas superadas y 4 omitidas sobre 238 recogidas, sin fallos.

La Tabla 13 presenta el resultado de la ejecución de referencia por control.

Tabla 13

Resultado de la ejecución de referencia contra el sistema desplegado

Control	Tipo	Qué evalúa	Conclusión	Resultado observado
C-01	Cumplimiento	Registro de actividad activo y con validación de integridad.	Conforme	El registro está activo y valida la integridad de sus archivos.
C-02	Cumplimiento	Cifrado en reposo con llave administrada y rotación.	Conforme	Cifrado por omisión con la llave del proyecto, rotación habilitada y objeto cifrado.
C-03	Cumplimiento	Ausencia de acceso público al almacén de evidencias.	Conforme	Los cuatro indicadores de bloqueo están activos.
C-04	Cumplimiento	Conservación de versiones anteriores.	Conforme	El versionado del almacén está habilitado.
C-05	Sustantiva	Autorización por rol con registro del intento.	Conforme	La operación no autorizada se rechaza con 403 y el intento queda registrado.
C-06	Sustantiva	Aislamiento entre organizaciones.	Conforme	Ninguna ruta de lectura cruza la frontera de organización; el intento queda registrado.
C-07	Sustantiva	Rechazo de transiciones de estado inválidas.	Conforme	Las tres transiciones inválidas se rechazan con 400 y quedan registradas.
C-08	Integridad	Detección de alteraciones en la bitácora.	Conforme	La cadena verifica sobre la bitácora íntegra y las tres alteraciones se detectan.
C-09a	Cumplimiento	Secretos en el árbol actual del repositorio.	Conforme	Ningún secreto versionado en los 209 archivos del árbol actual.
C-09b	Cumplimiento	Secretos en el historial de commits.	Desviado	Un secreto de firma en el historial, ya fuera del árbol actual. Catorce commits revisados.
C-09c	Sustantiva	Vigencia de los secretos hallados.	Conforme	Los dos secretos probados son rechazados por firma inválida.

Nota. Ejecución 20260926T235724886Z-4f87a8 del 26 de septiembre de 2026. Once resultados: diez conformes, uno desviado, ninguno sin ejecutar. Cada control conserva su papel de trabajo con la salida literal y su huella SHA-256, publicada en el informe.

La Tabla 14 recoge los hallazgos emitidos por la ejecución de referencia.

Tabla 14

Hallazgos emitidos y su tratamiento

Hallazgo	Severidad	Condición	Recomendación y estado
H-01	Media	Un secreto de firma permanece en el historial de commits del repositorio, fuera ya del árbol actual. Se versionó en un commit concreto; retirar el archivo después no lo saca del historial.	Reescribir el historial y forzar la actualización de las ramas públicas. No sustituye a la rotación, que ya se ejecutó. Aceptado con plan: el secreto fue invalidado y su vigencia se comprueba en C-09c.
H-PERM-01	Alta, permanente	Las funciones del sistema auditado comparten un único rol de ejecución con permisos amplios en lugar de disponer cada una de un rol restringido.	Un rol por función con políticas acotadas en un despliegue productivo. Fuera del alcance automatizado: el entorno impide corregirlo y una prueba que siempre da el mismo resultado no aporta información.
H-PERM-02	Media, permanente	El programa de auditoría se ejecuta con el mismo rol compartido, que dispone de permisos de escritura sobre los recursos que audita.	Ejecutar con credenciales de solo lectura y almacenar los papeles en una cuenta distinta de la auditada. Debilita el valor probatorio y se declara en cada informe.

Nota. Los dos hallazgos permanentes se declaran en todo informe en lugar de omitirse. Omitirlos transmitiría una cobertura mayor que la real, que es precisamente el riesgo que el catálogo busca evitar.

9.3 Validación con usuarios o expertos

Validación con usuarios externos: no aplica en esta entrega. El programa no fue operado por auditores ajenos al equipo, de modo que no puede reportarse evidencia sobre su utilidad percibida ni sobre la comprensibilidad del informe para un tercero. El equipo se abstiene de afirmar resultados que no ha medido.

En sustitución se aplicaron dos validaciones de otra naturaleza. La primera es la **reproducibilidad entre ejecuciones**: el programa se ejecutó dos veces el mismo día contra el mismo sistema, con una sola diferencia introducida deliberadamente entre ambas, que fue cargar una evidencia de entrega en el sistema auditado. La primera ejecución reportó el control C-02 como desviado por

ausencia de objeto sobre el que comprobar el cifrado; la segunda, con el objeto presente, lo reportó conforme. Los diez controles restantes mantuvieron su clasificación. La comparación demuestra que el resultado depende del estado del sistema y no del momento ni de quien ejecuta, que es la condición de REQ-08.

La segunda es la **prueba de contrato con el sistema auditado**, que verifica que el programa sigue obteniendo tokens válidos para cada rol y organización. Un programa de auditoría que dependa de un formato que no controla necesita detectar su cambio antes de que produzca un falso resultado. De esa comparación entre ejecuciones surgió además una observación metodológica que el equipo registra como mejora pendiente. Clasificar C-02 como desviado cuando no existía objeto sobre el que comprobar el cifrado fue impreciso: el propio informe define la tercera conclusión para los controles que no pudieron probarse, y ese era el caso. El criterio de C-02 tiene tres partes, y dos de ellas, la configuración del almacén y la rotación de la llave, son comprobables sin ningún objeto. Partir C-02 como se partió C-09 evitaría que un almacén vacío produjera un hallazgo de severidad alta. La corrección figura en el trabajo futuro.

10. Seguridad, privacidad, ética y cumplimiento

Independencia. El equipo audita un sistema que él mismo construyó, lo que constituye una amenaza de autorrevisión: quien evalúa un control tiende a confirmar la decisión que tomó al diseñarlo. Se aplican tres medidas. La rotación interna, de modo que ningún integrante ejecuta ni evalúa las pruebas del componente que construyó. El determinismo del programa, de modo que su resultado no depende del criterio de quien lo ejecuta. Y la posibilidad de reejecución por un tercero, que puede contrastar clasificaciones y huellas. Aun con esas medidas, este trabajo no alcanza el grado de independencia de una revisión externa, y el informe lo hace constar.

Existe un dato que respalda la eficacia de esas medidas mejor que la argumentación. El programa detectó un defecto de seguridad real introducido por el propio equipo, que las revisiones manuales del código y de la documentación no habían advertido. Un programa determinista con criterio declarado de antemano encontró lo que sus autores no vieron.

Incidente de seguridad gestionado durante la construcción. El archivo de configuración con el secreto de firma de sesiones del sistema auditado quedó versionado en el repositorio público durante aproximadamente veintisiete minutos. La causa raíz no fue un descuido aislado: la exclusión del archivo existía y se retiró junto con todas las exclusiones de archivos generados, al versionar las evidencias de despliegue. La respuesta fue rotar el secreto y redespargar las funciones, comprobar que ninguna conserva el anterior y que un token firmado con él es rechazado, excluir de nuevo el archivo y repetir la verificación del despliegue. El análisis de la ventana de exposición no encontró indicios de explotación. El riesgo residual, la permanencia del secreto en el historial, se acepta de forma temporal porque el secreto fue invalidado y queda registrado como hallazgo H-01.

Este episodio produjo el control C-09, y con él una consecuencia de diseño: el detector registra la ruta y el commit, nunca el valor encontrado. Un papel de trabajo que citara el secreto volvería a exponerlo, y los papeles se entregan al evaluador.

Limitación de privilegios del propio programa. El ejecutor corre con el mismo rol compartido del laboratorio, que dispone de permisos de escritura sobre los recursos que audita. Un auditor con permisos de escritura no es un auditor: técnicamente podría modificar la evidencia que evalúa. La condición se declara como hallazgo permanente H-PERM-02 y no como una característica aceptable del diseño. La recomendación es ejecutar con credenciales de solo lectura y almacenar los papeles en una cuenta distinta de la auditada, algo que el entorno no permite.

Confidencialidad de los papeles de trabajo. El almacén concentra información sobre las debilidades del sistema auditado, y su divulgación facilitaría un ataque. Por eso los papeles no se versionan en el repositorio público y se entregan de forma directa al evaluador. Es la misma lección del incidente anterior, aplicada antes de que ocurra.

Integridad del ejercicio. Un principio gobierna toda la ejecución: ninguna prueba se reporta como realizada si no se ejecutó, y ningún resultado se ajusta para que un control aparezca como conforme. La tercera conclusión existe precisamente para no tener que elegir entre aprobar y reprobar lo que no se pudo revisar.

11. Calidad, mantenibilidad y operación

La **extensibilidad** fue el atributo de calidad que más condicionó el diseño: el catálogo vive en un archivo de datos, de modo que añadir un control no exige tocar el ejecutor. Esa propiedad se puso a prueba durante la construcción, cuando hubo que incorporar el control de secretos con urgencia tras el incidente, y funcionó.

La **verificabilidad** se apoya en las 34 pruebas del propio programa y en su ejecución sin credenciales del proveedor, que permite a cualquiera repetirlas. La **comprensibilidad** se trató como atributo de calidad y no como presentación: cada control declara su versión en lenguaje llano en el catálogo, no en la interfaz, de modo que la consola, el informe y la web digan lo mismo. Un hallazgo que el responsable no entiende no se corrige.

La **operabilidad** descansa en el código de salida diferenciado, que distingue conformidad, desviación y controles sin ejecutar, y permite integrar el programa en una cadena automatizada. La ejecución es por demanda y no continua, porque el entorno cierra la sesión cada cuatro horas. Sobre la deuda técnica reconocida, el equipo señala tres elementos. La validación en doble sentido no está automatizada para los controles de cumplimiento. El control C-02 debería partirse como

se partió C-09. Y el sellado por función hash no permite verificar sin acceder a los papeles. Los tres figuran en el trabajo futuro con su justificación.

12. Gestión del proyecto

12.1 Metodología, fases y roles

El proyecto siguió la secuencia de un trabajo de aseguramiento conforme al marco de prácticas profesionales de auditoría de sistemas (ISACA, 2020): planeación y definición del universo auditable, diseño del programa de pruebas, ejecución y obtención de evidencia, y evaluación y comunicación de resultados. Sobre esa secuencia se superpuso un ciclo incremental de construcción, porque el ejecutor se desarrolló en paralelo con el sistema que iba a auditar y solo podía probar controles ya implementados.

Una regla metodológica gobernó todo el trabajo: el criterio de cada prueba se declara antes de ejecutarla. El catálogo lleva fecha anterior a la primera ejecución precisamente para que el criterio no pueda acomodarse al resultado.

La Tabla 15 presenta las fases ejecutadas con sus responsables y su estado.

Tabla 15

Fases del proyecto, responsables y estado

Fase	Actividades	Responsable	Estado
F1. Planeación	Definición del universo auditable, derivación del catálogo desde los marcos y asignación de la rotación de independencia.	Oscar Julián Rincón	Cerrada. Catálogo con fecha anterior a la primera ejecución.
F2. Diseño del programa	Procedimiento, criterio y evidencia esperada de cada prueba; diseño del almacén de papeles.	Sergio Alejandro Montoya	Cerrada.
F3. Construcción	Ejecutor, tres familias de pruebas, almacén, informe e interfaz de consulta.	Nicolás Torres	Cerrada. Programa operativo.

Fase	Actividades	Responsable	Estado
F4. Ejecución y comunicación	Ejecución contra el sistema desplegado, evaluación de desviaciones, ampliación del catálogo tras el incidente y redacción del informe.	Oscar Julián Rincón	En curso. Cierra con esta entrega.

Nota. La regla de independencia interna condiciona la asignación: quien construyó un componente del sistema auditado no ejecuta ni evalúa las pruebas de ese componente, y la reejecución de la fase 4 la realiza un integrante distinto de quien desarrolló el ejecutor.

12.2 Cronograma e hitos

Los cuatro hitos comprometidos se cumplieron. El catálogo quedó aprobado antes de construir el ejecutor, el programa de pruebas se documentó antes de implementarlo, el programa quedó operativo y la ejecución contra el sistema desplegado se realizó el 26 de septiembre de 2026.

La desviación principal fue la ampliación del catálogo durante la fase 4, provocada por el incidente de seguridad. No estaba planificada y consumió tiempo previsto para la validación en doble sentido de los controles de cumplimiento, que por eso queda como trabajo futuro. El equipo considera que el intercambio fue favorable: un control derivado de un riesgo materializado vale más que la automatización de una validación sobre controles que ya resultaron conformes.

12.3 Repositorio, versiones y gestión de cambios

El repositorio público del proyecto es <https://github.com/Serann10255/Rastro>. El programa de auditoría reside en una carpeta propia y comparte repositorio con el sistema auditado, porque comparten objeto: no tendría sentido versionar por separado un programa cuyo propósito es verificar al otro.

Se versionan el catálogo de controles, el código del ejecutor y de las tres familias de pruebas, el almacén, el generador de informe, la interfaz y las pruebas del propio programa. **Los papeles de trabajo no se versionan**, por la razón expuesta en el apartado 10, y se entregan de forma directa

al evaluador. Las credenciales de los usuarios de prueba se suministran por variable de entorno y tampoco se versionan.

Declaración de uso de herramientas de inteligencia artificial. El equipo utilizó Claude, un asistente conversacional basado en modelos de lenguaje de gran escala (Anthropic, 2026), como apoyo en la redacción y la estructuración de este documento y en la elaboración de las figuras. La definición del universo auditable, la derivación del catálogo, el desarrollo del programa, la ejecución de la auditoría y la evaluación de los hallazgos corresponden a los integrantes del equipo, que asumen la responsabilidad sobre la exactitud del contenido y sobre la verificación de las fuentes citadas.

12.4 Presupuesto y recursos

El programa se ejecuta por demanda y su consumo es marginal frente al del sistema auditado: consultas de configuración en modo lectura, unas pocas peticiones a la interfaz del sistema y almacenamiento local de los papeles de trabajo. No incorpora ningún componente con cargo adicional, porque reutiliza los recursos ya existentes en la cuenta.

El equipo no reporta cifras de consumo que no haya verificado. Los recursos humanos fueron tres integrantes con dedicación parcial durante el periodo académico.

13. Viabilidad y gestión de riesgos actualizadas

La viabilidad **técnica** queda confirmada: el programa está construido y ejecutado contra un sistema real. La **operativa** se confirma en cuanto a disciplina de procedimiento, porque el programa registra automáticamente lo que hizo sin depender de que alguien lo anote, pero se mantiene condicionada por la limitación de independencia. La **económica** no presenta riesgo. La **legal y ética** queda cubierta por la operación con datos sintéticos y por las declaraciones del apartado 10.

La Tabla 16 actualiza el estado de los riesgos identificados al cierre de la entrega.

Tabla 16

Riesgos actualizados con su estado al cierre

ID	Riesgo	Prob.	Impacto	Estado al cierre	Respuesta aplicada
R-01	El sistema auditado no implementa a tiempo los controles y el alcance se reduce a cumplimiento.	Alta	Alto	No materializado	Sincronización con el avance del sistema auditado y prioridad a las pruebas que no dependen de la aplicación. Las tres familias se ejecutaron.
R-02	Un defecto del propio ejecutor clasifica como conforme un control que no lo está.	Media	Muy alto	No materializado, mitigación parcial	Validación en doble sentido integrada en C-08 y 34 pruebas del programa. Para los controles de cumplimiento la validación no está automatizada; se declara como deuda.
R-03	La autorrevisión sesga la evaluación de un control diseñado por el propio evaluador.	Media	Alto	No materializado	Rotación interna, criterio tomado de marcos externos y declaración expresa. El programa detectó un defecto propio, lo que respalda la eficacia de la medida.
R-04	El catálogo omite un control relevante porque nadie lo programó.	Media	Medio	Materializado y corregido	Se materializó: el catálogo no cubría los secretos en el repositorio. Se incorporó el control C-09 en tres comprobaciones tras el incidente.
R-05	La expiración de credenciales interrumpe una ejecución a la mitad.	Alta	Bajo	No materializado	El ejecutor marca la ejecución como incompleta, de modo que un resultado ausente nunca se confunde con una desviación.
R-06	Se pierde el acceso a la cuenta y con él la evidencia almacenada.	Media	Alto	No materializado	Los papeles de trabajo residen fuera de la cuenta auditada, en el equipo del auditor.
R-07	Un control informa desviación por ausencia de	Media	Medio	Materializado y corregido	Riesgo no previsto. Ocurrió con C-02 sobre un almacén vacío. Se

ID	Riesgo	Prob.	Impacto	Estado al cierre	Respuesta aplicada
	objeto sobre el que probar, y no por incumplimiento.				corrigió cargando la evidencia y se registra la participación del control como trabajo futuro.

Nota. R-07 se incorpora en esta entrega. Su omisión inicial fue un defecto del análisis: un control cuyo criterio depende de la existencia de un objeto debió contemplar desde el principio el caso en que ese objeto no exista.

14. Resultados y discusión

El resultado principal es que el programa funciona y que su funcionamiento quedó demostrado del modo más concluyente posible: encontró un problema real que sus propios autores no habían visto.

Un secreto de firma versionado en un repositorio público sobrevivió a las revisiones manuales del código y de la documentación, y lo detectó un control automatizado con criterio declarado de antemano. Ese episodio es, a juicio del equipo, el hallazgo más instructivo del proyecto, porque valida empíricamente el planteamiento del apartado 3.1: quien construye un sistema no es un buen verificador de sus propios controles.

Frente a los antecedentes, el aporte se sitúa donde la revisión identificó el vacío. De los once resultados de la ejecución de referencia, cuatro corresponden al comportamiento efectivo de controles que viven en el código de la aplicación: autorización por rol, aislamiento entre organizaciones, validez de las transiciones y vigencia de los secretos hallados. Ninguno de esos cuatro habría sido verificable por un servicio de evaluación de configuración, por solvente que fuera. La auditoría continua descrita por Vasarhelyi y Halper (1991) se materializa aquí en el plano que Chan y Vasarhelyi (2011) identificaron como el obstáculo real: definir con precisión qué constituye una excepción y qué evidencia la sustenta.

Los resultados negativos también se reportan, y son dos. El primero es el control desviado: un secreto permanece en el historial del repositorio. Está acotado en su efecto, porque fue invalidado y el propio programa comprueba que el sistema lo rechaza, pero es una desviación y se cuenta

como tal. El segundo es un defecto metodológico del propio programa: en la primera ejecución, el control C-02 informó desviación cuando lo correcto habría sido informar que no pudo probarse, porque el almacén estaba vacío. El programa define la tercera conclusión precisamente para ese caso y no la aplicó. Es un error de diseño del control, no de la ejecución, y se corrige partiendo el criterio como se hizo con C-09.

Tres limitaciones acotan el alcance de estas conclusiones. La primera es la independencia: ninguna medida interna elimina que el equipo audite su propio trabajo. La segunda es la cobertura: el programa verifica únicamente los controles del catálogo, y un control ausente no fue evaluado; derivar el catálogo de marcos externos hace que su alcance sea una decisión y no un olvido, pero no lo amplía. La tercera es el valor probatorio de los papeles: el ejecutor corre con permisos de escritura sobre lo que audita, de modo que el esquema ofrece detección de alteraciones y no imposibilidad de alterarlas.

Sobre esa tercera limitación conviene ser preciso, porque delimita lo que el proyecto puede afirmar. La huella SHA-256 permite comprobar que un papel de trabajo no fue modificado después de escribirse, siempre que el índice que la guarda tampoco lo haya sido. Frente a quien controla la cuenta, esa garantía no se sostiene. Resolverlo exigiría una firma cuya clave privada no fuera extraíble y un anclaje fuera de la cuenta auditada, y ninguna de las dos cosas se construyó ni el entorno las permite.

15. Conclusiones, recomendaciones y trabajo futuro

15.1 Conclusiones

El programa responde la pregunta de proyecto: es posible verificar de forma automatizada y reproducible los controles de un sistema desplegado en la nube, cubriendo tanto la configuración

de la infraestructura como el comportamiento efectivo de la aplicación, y produciendo papeles de trabajo trazables a un marco de referencia. La respuesta está sostenida por una ejecución real contra un sistema desplegado y no por una demostración.

La conclusión con mayor valor práctico es que la verificación automatizada encontró lo que la revisión manual no vio. No se trata de que el programa sea más inteligente, sino de que aplica un criterio declarado antes de conocer el resultado, y eso es precisamente lo que un revisor humano no puede garantizar sobre su propio trabajo.

La segunda conclusión es metodológica: declarar el criterio antes de ejecutar y admitir una tercera conclusión para lo que no se pudo probar son dos decisiones baratas que determinan si un informe de auditoría dice la verdad o transmite más cobertura de la que tuvo. El propio proyecto ilustró el riesgo cuando clasificó mal un control, y el error fue de diseño del criterio y no de la ejecución.

La tercera es que las limitaciones del entorno, lejos de invalidar el ejercicio, produjeron los dos hallazgos permanentes más instructivos: un sistema auditado que no puede aplicar el principio de mínimo privilegio y un auditor que no puede ejecutarse con permisos de solo lectura. Ambos se declaran en cada informe porque omitirlos transmitiría una garantía que no existe.

15.2 Recomendaciones y trabajo futuro

Cada línea indica su responsable sugerido, su prioridad, el esfuerzo estimado, aquello de lo que depende y el criterio con el que se considerará cerrada. Las que dependen de permisos o recursos que el entorno educativo no concede se señalan como tales.

La Tabla 17 relaciona cada acción correctiva con su responsable, su prioridad y su criterio de cierre.

Tabla 17

Plan de acciones correctivas y trabajo futuro

Acción	Responsable sugerido	Prioridad	Tiempo estimado	Dependencia	Criterio de cierre
Partir el control C-02 en configuración del almacén y cifrado del objeto.	Oscar Rincón	Alta	4 horas	Ninguna.	Con el almacén vacío, C-02a informa conforme y C-02b informa no ejecutada, sin producir hallazgo.
Automatizar la validación en doble sentido de los controles de cumplimiento.	Nicolás Torres	Alta	1 semana	Entorno desechable donde romper un control sin riesgo para el sistema auditado.	Cada control de cumplimiento informa desviación cuando el control se rompe deliberadamente.
Ejecutar el programa con credenciales de solo lectura y almacenar los papeles en una cuenta distinta.	Nicolás Torres	Alta	1 semana	Permiso para crear roles y disponer de una segunda cuenta, no concedidos por el entorno.	El hallazgo permanente H-PERM-02 se cierra y el ejecutor no dispone de escritura sobre lo que audita.
Firmar el índice con llave asimétrica y publicar el sello fuera de la cuenta auditada.	Sergio Montoya	Media	3 semanas	Llave con política separada del rol de ejecución, no disponible en el entorno.	Un tercero verifica que el índice no fue alterado sin necesidad de recibir los papeles de trabajo.
Habilitar retención inmutable en el almacén de papeles de trabajo.	Sergio Montoya	Media	4 horas	Que el entorno permita habilitar la retención en el contenedor.	Un intento de borrado o sobrescritura de un papel dentro del periodo de retención se rechaza.
Validar la comprensibilidad del informe con auditores ajenos al equipo.	Oscar Rincón	Media	2 semanas	Contacto con auditores externos dispuestos a revisar.	Tres lectores externos identifican la acción requerida de cada hallazgo sin ayuda del equipo.

Nota. La prioridad responde al riesgo que la acción reduce y no a su facilidad. Las dos primeras no dependen del entorno y son las que el equipo puede ejecutar de inmediato; las demás quedan condicionadas a permisos o recursos que el laboratorio no concede.

La recomendación principal para quien retome el programa es conservar las dos reglas que lo sostuvieron: declarar el criterio antes de ejecutar la prueba, y no clasificar como aprobado ni como reprobado aquello que no se pudo comprobar.

Referencias

- Amazon Web Services. (2024). AWS Well-Architected Framework: Security pillar.
<https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>
- Anthropic. (2026). Claude (versión Opus 5) [Modelo de lenguaje de gran escala].
<https://claude.ai>
- Barker, E. (2020). Recommendation for key management: Part 1 — General (NIST Special Publication 800-57 Part 1, Rev. 5). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-57pt1r5>
- Center for Internet Security. (s. f.). CIS Amazon Web Services Foundations Benchmark.
https://www.cisecurity.org/benchmark/amazon_web_services
- Chan, D. Y., & Vasarhelyi, M. A. (2011). Innovation and practice of continuous auditing. *International Journal of Accounting Information Systems*, 12(2), 152-160.
<https://doi.org/10.1016/j.accinf.2011.01.001>
- Congreso de la República de Colombia. (2012, 17 de octubre). Ley 1581 de 2012. Por la cual se dictan disposiciones generales para la protección de datos personales. Diario Oficial No. 48.587.
- Haber, S., & Stornetta, W. S. (1991). How to time-stamp a digital document. *Journal of Cryptology*, 3(2), 99-111. <https://doi.org/10.1007/BF00196791>
- International Organization for Standardization. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- ISACA. (2018). COBIT 2019 framework: Governance and management objectives. ISACA.

ISACA. (2020). ITAF: A professional practices framework for IS audit/assurance (4.^a ed.).

ISACA.

ISACA. (s. f.). Code of professional ethics. <https://www.isaca.org/credentialing/code-of-professional-ethics>

Kent, K., & Souppaya, M. (2006). Guide to computer security log management (NIST Special Publication 800-92). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-92>

OWASP Foundation. (2021). OWASP Top 10:2021 — A01:2021 Broken access control.

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. ACM Transactions on Information and System Security, 2(2), 159-176.

<https://doi.org/10.1145/317087.317089>

Vasarhelyi, M. A., & Halper, F. B. (1991). The continuous audit of online systems. Auditing: A Journal of Practice & Theory, 10(1), 110-125.

Anexos técnicos

Los anexos de código y documentación residen en el repositorio público del proyecto, <https://github.com/Serann10255/Rastro>, con permisos de lectura abiertos. Los papeles de trabajo se entregan de forma directa al evaluador por la razón expuesta en el apartado 10.

La Tabla 18 relaciona cada anexo con su ubicación y el apartado que lo cita.

Tabla 18

Anexos técnicos y su ubicación

Anexo	Ubicación	Apartado que lo cita
Catálogo de controles	cotejo/catalogo/controles.yaml	6.2
Ejecutor y familias de pruebas	cotejo/cotejo/	8.1
Almacén de papeles de trabajo	cotejo/cotejo/papeles.py	7.1
Generador de informe	cotejo/cotejo/informe.py	7.2
Interfaz de consulta de la auditoría	cotejo/api/ y cotejo/web/	7.2
Pruebas del propio programa	cotejo/tests/	9.1 y 9.2
Documentación del módulo	documentacion/modulos/cotejo/	8
Informe de la ejecución de referencia	Entrega directa al evaluador. Ejecución 20260926T235724886Z-4f87a8	9.2
Papeles de trabajo con sus huellas	Entrega directa al evaluador. No se versionan.	7.1, 9.2 y 10
Gestión del incidente de seguridad	documentacion/cambios/2026-09-26-h01-secreto-expuesto.md	10

Nota. El informe de la ejecución de referencia publica la huella SHA-256 de cada papel de trabajo, de modo que el evaluador puede comprobar que los archivos que recibe son los que el informe cita.